AWS CLOUD NETWORKING & SECURITY

Lab Configuration & Practical Solutions

Complete implementation guide for Security Groups, State Control, and Network ACLs

Task 1: InstaClone Web Tier Security Configuration

`InstaClone-SG`

> **Problem Statement:** Create an AWS Security Group named `InstaClone-SG` configured to allow inbound HTTP (Port 80) and HTTPS (Port 443) traffic strictly from your own IP address.

Configuration Steps:

1. Navigate to **EC2 Management Console** > **Network & Security** > **Security Groups**.
2. Click **Create security group**. Set Name to `InstaClone-SG` and add a description (e.g., *"Restricted admin web access for InstaClone"*). Select target VPC.
3. Under **Inbound Rules**, add two distinct ingress entries:

Type	Protocol	Port Range	Source	Description
HTTP	TCP	80	`My IP` (`YOUR_PUBLIC_IP/32`)	Allow HTTP admin testing
HTTPS	TCP	443	`My IP` (`YOUR_PUBLIC_IP/32`)	Secure SSL/TLS web access

> **Key Insight:** AWS automatically appends `/32` to represent a single IPv4 host address. All other incoming traffic is implicitly denied by default.

Task 2: Zomato-Style Database Tier Lockdown

`Zomato-DB-SG`

> **Problem Statement:** Set up a security group for a mock backend server that allows inbound MySQL (port 3306) traffic only from a specified backend/app server IP in CIDR format, blocking all other incoming connections.

Configuration Steps:

1. In the **Security Groups** dashboard, click **Create security group**.
2. Name: `Zomato-Backend-DB-SG`. Description: *"Restricted MySQL access for app instances"*.
3. In **Inbound Rules**, click **Add rule** using Custom TCP / MySQL specification:

Type	Protocol	Port Range	Source Type	CIDR Value
MySQL/Aurora (or Custom TCP)	TCP	3306	Custom	`192.168.1.50/32` *(or App SG ID)*

> **Security Architecture Best Practice:** Because Security Groups operate with an implicit default deny rule (whitelisting only), any connection outside the specified `/32` CIDR is automatically dropped at the hypervisor level.

Task 3: Strict Outbound Lockdown for Paytm Wallet Server `Paytm-Wallet-SG`

> **Problem Statement:** Modify an existing security group to deny all outbound traffic except DNS (port 53) and HTTPS (port 443) to simulate an ultra-secure, compliant payment processing environment.

Modification Procedure:

1. Locate and select the target Security Group; open the **Outbound rules** tab.
2. Click **Edit outbound rules**.
3. **Delete** the default permissive rule: `All traffic | All | All | 0.0.0.0/0`.
4. Add the required egress rules allowing only resolved DNS queries and secure external API webhooks:

Type	Protocol	Port Range	Destination	Purpose
DNS (UDP)	UDP	53	`0.0.0.0/0` *(or VPC CIDR + 2)*	Domain resolution queries
DNS (TCP)	TCP	53	`0.0.0.0/0`	Large payload DNS fallback
HTTPS	TCP	443	`0.0.0.0/0` *(or Payment Gateway IP)*	Encrypted banking / API calls

> **Crucial State Detail:** Return packets corresponding to established inbound requests bypass egress restrictions automatically due to the *stateful* nature of Security Groups.

Task 4: Flipkart Cloud Architecture – Security Groups vs Network ACLs `Deep Comparison`

> **Problem Statement:** Compare Security Groups and Network ACLs by detailing two fundamental architectural differences in how they govern traffic for large-scale enterprise workloads like Flipkart.

Evaluation Dimension	Security Groups (Instance Level)	Network ACLs (Subnet Level)
1. Operating Level & Scope	**Instance / ENI Level:** Acts as a virtual firewall directly for EC2 instances, ECS containers, or RDS nodes. Different instances within the exact same subnet can have distinct security group profiles applied.	**Subnet Level:** Acts as a boundary perimeter firewall for an entire subnet. Traffic must clear the subnet NACL before it can ever reach any instance inside that subnet.
2. Direction & State Tracking	**Stateful Filtering:** Inbound and outbound connections are dynamically tracked. If an inbound request is permitted, response traffic is automatically allowed back out regardless of outbound rules.	**Stateless Filtering:** Return traffic is NOT tracked automatically. Explicit inbound AND outbound rules must be maintained (e.g., allowing ephemeral ports 1024–65535 for responses).
3. Rule Evaluation & Explicit Deny	**Allow Rules Only:** Evaluates all rules across the group; cannot define explicit DENY rules. Any unlisted port is dropped.	**Numbered Rules + Explicit Deny:** Processes rules in numerical order (lowest first). Allows explicit DENY rules (vital for blocking rogue IP addresses/DDoS sources).